

شركة دايموند لوساطة التأمين
سياسة أمن مستخدمي تقنية المعلومات
مايو 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الثمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



Internal

DO NOT COPY

معلومات السياسة				
سياسة أمن مستخدمي تقنية المعلومات			عنوان السياسة	
مُسْتَحْدَثَة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
1ITM0003			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
إدارة تقنية المعلومات			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	29/07/2025	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	29/07/2025	شادن سلطان العتيبي	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	29/07/2025	بدر سعد الشايع	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة أمن مستخدمي تقنية المعلومات جزءاً أساسياً لوضع الإطار العام لسلوك المستخدمين داخل بيئة العمل التقنية، وضمان الالتزام بالضوابط الأمنية التي تحمي أصول المعلومات والأنظمة المستخدمة في الشركة.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو حماية سرية وسلامة وتوافر المعلومات من خلال توجيه سلوك المستخدمين نحو استخدام آمن ومسؤول للأنظمة التقنية والبنية التحتية الرقمية.

3. تعاريف:

- 3.1 دايموند : شركة الوثيقة الماسية لوساطة التأمين.
- 3.2 أمن مستخدمي تقنية المعلومات :مجموعة الضوابط والتعليمات التي تنظم سلوك المستخدمين أثناء استخدامهم لأنظمة وأجهزة وتقنيات الشركة، لضمان الحماية من التهديدات السيبرانية وحوادث إساءة الاستخدام.
- 3.3 المستخدم: أي موظف، متدرب، استشاري، أو طرف ثالث يملك صلاحية استخدام أحد أنظمة تقنية المعلومات في الشركة.
- 3.4 المستخدم الخارجي: شخص لا يتبع للهيكل التنظيمي الدائم للشركة، مثل مزودي الخدمات أو شركاء التأمين.
- 3.5 الصلاحيات المؤقتة: صلاحيات تُمنح لفترة محددة لإنجاز مهام خاصة، ثم تُسحب تلقائياً.
- 3.6 الأنظمة الحرجة: الأنظمة التي تمس البيانات الحساسة مثل نظام علاقات العملاء (CRM)، ونظام إصدار الوثائق، وأنظمة الربط مع شركات التأمين.
- 3.7 سلوك الاستخدام غير المشروع: أي استخدام يتناقض مع ضوابط السياسة، كالمشاركة غير المصرح بها، أو نقل البيانات خارج الأنظمة الآمنة.
- 3.8 المصادقة متعددة العوامل (MFA): وسيلة أمان تعتمد على التحقق من هوية المستخدم باستخدام أكثر من طريقة (مثل كلمة المرور + رمز تحقق على الجوال).
- 3.9 VPN (Virtual Private Network): شبكة خاصة افتراضية تُستخدم لتأمين الاتصال بين المستخدم والأنظمة الداخلية للشركة عند العمل عن بُعد.
- 3.10 بيانات مصنفة Classified Data: أي بيانات تحمل تصنيفاً أمنياً مثل "سري"، "داخلي"، أو "حساس"، وتتطلب حماية إضافية حسب سياسات التصنيف.
- 3.11 إدارة الجودة والتطوير
- 3.12 التصيد الإلكتروني (Phishing): أسلوب احتيالي يستخدم الرسائل الإلكترونية لخداع المستخدمين وسرقة معلوماتهم أو الدخول إلى أنظمة الشركة.
- 3.13 نظام إدارة الأصول التقنية: نظام إلكتروني يُستخدم لحصر ومتابعة وتوثيق جميع أجهزة وتقنيات الشركة المخصصة للمستخدمين.
- 3.14 إخلاء الطرف التقني: إجراء رسمي يُنفذ عند انتهاء علاقة الموظف بالشركة، ويتضمن إعادة الأجهزة والتأكد من إلغاء الصلاحيات التقنية.
- 3.15 برمجيات غير مصرح بها (Unauthorized Software): أي برنامج لم يتم اعتماده أو ترخيصه من قبل إدارة تقنية المعلومات، ويُحظر تثبيته أو استخدامه.
- 3.16 الوسائط الخارجية (External Media): أجهزة مثل USB، أقراص صلبة خارجية، وأقراص DVD تُستخدم لنقل البيانات، وتخضع لضوابط أمنية صارمة.
- 3.17 Tamper Protection: خاصية تقنية تمنع التعديل أو الإيقاف غير المصرح به لبرامج الحماية.

3.18 سجل الحوادث التقنية: قاعدة بيانات تُسجل فيها جميع البلاغات الأمنية المرتبطة بالمستخدمين، مثل محاولات الدخول غير المصرح أو فقدان الأجهزة.

3.19 الموارد التقنية: تشمل جميع الأجهزة، الشبكات، البرمجيات، البريد الإلكتروني، وأنظمة الشركة المستخدمة لتنفيذ الأعمال اليومية.

3.20 مراقبة الاستخدام اللحظي (Real-Time Monitoring): هي عملية تتبع فوري لأنشطة المستخدمين على الأنظمة الحرجة باستخدام أدوات تقنية تصدر تنبيهات فورية عند اكتشاف نشاط غير طبيعي.

3.21 الاختبارات التصيدية: تمارين أمنية وهمية تُجرى على الموظفين بهدف قياس مدى وعيهم تجاه محاولات التصيد الإلكتروني، وتُستخدم لتوجيه التدريب الأمني.

3.22 الأدوات المؤقتة: صلاحيات تُمنح لمستخدم معين لفترة محددة بهدف تنفيذ مهمة محددة، ويتم إلغاؤها تلقائيًا عند انتهاء الوقت المحدد.

4. نطاق تطبيق السياسة :

4.1 تُطبق هذه السياسة على كافة مستخدمي الأنظمة التقنية داخل الشركة، وتشمل:

4.1.1 الموظفين الدائمين والمؤقتين

4.1.2 المتدربين والمقاولين

4.1.3 المستخدمين الخارجيين المفوضين بالوصول إلى أنظمة الشركة

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات. قسم الأمن السيبراني.

6. الكيانات ذات العلاقة:

6.1 كافة الكيانات المملوكة بالكامل إلى شركة دايمنود.

6.2 المزودون التقنيون المعتمدون.

6.3 الجهات الرقابية (هيئة التأمين ، هيئة الأمن السيبراني)



إدارة الجودة والتطوير Quality & Development Management

7. قواعد عامة:

7.1 الاستخدام المسؤول لحسابات النظام:

- 7.1.1 يجب على جميع المستخدمين استخدام حساباتهم الشخصية فقط عند الدخول إلى أي نظام من أنظمة الشركة، ويُمنع منعاً باتاً استخدام حساب مستخدم آخر حتى في حال غيابه أو بإذنه. ويُعد هذا التصرف خرقاً أمنياً صريحاً.
- 7.1.2 يجب على المستخدم الحفاظ على سرية اسم المستخدم وكلمة المرور، ويُمنع تدوينها في أماكن غير آمنة أو مشاركتها شفهيًا أو كتابيًا أو إلكترونيًا، وتُعد هذه المشاركة مخالفة أمنية جسيمة.
- 7.1.3 يُلزم المستخدم بتسجيل الخروج من جميع الأنظمة عند الانتهاء من استخدامها، وعدم ترك الجلسات مفتوحة.
- 7.1.4 في حال الاشتباه بأن حساب المستخدم قد تم اختراقه أو استخدامه بطريقة غير مشروعة، يجب على المستخدم الإبلاغ الفوري لمسؤول الأمن السيبراني عبر البريد الإلكتروني الرسمي أو وسيلة الاتصال المعتمدة، مع تقديم وصف للحالة، وتوثيق التاريخ والوقت ونوع النشاط المشبوه. وتحديد نوع الشكوى كـ "حادثة أمنية".

7.2 إدارة الحسابات والصلاحيات:

- 7.2.1 يجب إنشاء حسابات المستخدمين بناءً على طلب رسمي معتمد من المدير المباشر، ويتضمن تحديد نوع الحساب والصلاحيات المطلوبة بدقة.
- 7.2.2 يجب أن تتناسب صلاحيات الحسابات مع المهام الفعلية للمستخدم، ويُحظر منح صلاحيات زائدة عن الحاجة التشغيلية.
- 7.2.3 يجب مراجعة صلاحيات المستخدمين دوريًا كل ثلاثة (3) أشهر من قبل إدارة الأمن السيبراني، مع إيقاف الحسابات غير المستخدمة تلقائيًا بعد مرور ثلاثين (30) يومًا.
- 7.2.4 يُمنع منعاً باتاً إنشاء أو استخدام الحسابات العامة أو المشتركة لأي غرض، ويُعد ذلك خرقاً أمنياً.
- 7.2.5 يجب تسجيل كافة الأنشطة المرتبطة باستخدام حسابات المستخدمين، بما في ذلك الدخول إلى الأنظمة، تنفيذ المعاملات، وإجراء التعديلات، وخاصة داخل الأنظمة الحرجة مثل CRM وأنظمة الربط مع شركات التأمين.
- 7.2.6 يجب حفظ هذه السجلات في قاعدة بيانات مؤمنة لمدة لا تقل عن عشر (10) سنوات، وفقاً لمتطلبات هيئة التأمين السعودية.
- 7.2.7 يجب أن تحتوي السجلات على تفاصيل دقيقة مثل: اسم المستخدم، التاريخ، الوقت، نوع العملية، اسم النظام، الجهاز المستخدم، والموقع الجغرافي إن أمكن.
- 7.2.8 يجب استخدام هذه السجلات كمرجع رئيسي في حال ورود شكاوى العملاء، أو التحقيقات الرقابية، أو اكتشاف مخالفات تشغيلية.

7.3 حماية كلمات المرور:

- 7.3.1 يجب إنشاء كلمات مرور معقدة لا تقل عن 12 خانة وتحتوي على أحرف كبيرة وصغيرة وأرقام ورموز.
- 7.3.2 يُلزم المستخدم بتحديث كلمة المرور كل 90 يومًا، وعدم إعادة استخدام كلمات المرور السابقة.
- 7.3.3 يُمنع استخدام كلمات مرور موحدة أو ضعيفة (مثل: 123456 أو admin123).
- 7.3.4 تُفعل خاصية القفل التلقائي للحساب بعد 5 محاولات فاشلة للدخول.

7.4 البريد الإلكتروني والاستخدامات الرقمية:

- 7.4.1 يجب استخدام البريد الإلكتروني الرسمي لأغراض العمل فقط، ويُمنع استخدامه لتسجيل الدخول إلى مواقع أو تطبيقات شخصية.
- 7.4.2 يُحظر فتح روابط أو مرفقات من مصادر مجهولة أو مشبوهة ويجب الإبلاغ عنه فوراً.
- 7.4.3 يُمنع إرسال معلومات سرية عبر البريد دون تشفير أو موافقة مسبقة من مشرف تقنية المعلومات.
- 7.4.4 يُحتفظ بجميع رسائل البريد الإلكتروني المتعلقة بالعمل وفق سياسة الاحتفاظ بالوثائق.

7.5 حوكمة الحسابات ذات الصلاحيات المرتفعة:

- 7.5.1 الحسابات الإدارية (مثل حسابات Administrator أو Root) تُدار تحت رقابة صارمة، وتُسجل جلساتها بالكامل.
- 7.5.2 لا يُسمح باستخدام الحساب الإداري لأغراض التصفح أو البريد أو الأنشطة اليومية.
- 7.5.3 يجب تغيير كلمة مرور الحساب الإداري بعد كل استخدام طارئ، ولا تُستخدم من أكثر من شخص.
- 7.5.4 استخدام الشبكات والاتصال عن بعد:
- 7.5.5 يُمنع الاتصال بأنظمة الشركة من خارج مقر العمل إلا باستخدام شبكة VPN مصادق عليها، وتحت رقابة أمنية.
- 7.5.6 يُمنع استخدام شبكات Wi-Fi عامة للوصول إلى بيانات العمل.

- 7.5.7 يجب تفعيل الجدار الناري وبرامج الحماية قبل الاتصال بأي شبكة خارجية.
- 7.6 التعامل مع البيانات المصنفة:
- 7.6.1 يجب الالتزام بسياسة تصنيف المعلومات، ويُمنع نقل أو مشاركة أو تعديل البيانات المصنفة دون تصريح من مالك المعلومة.
- 7.6.2 يُحظر نسخ البيانات المصنفة "سرية" على وسائط تخزين متنقلة دون إذن مكتوب.
- 7.6.3 تُخزن البيانات المصنفة باستخدام وسائل مشفرة (AES-256) وتحت إشراف تقني مباشر.
- 7.7 العمل خارج المكتب وأثناء التنقل:
- 7.7.1 يُمنع الاتصال بأنظمة الشركة من خارج بيئة العمل إلا عبر VPN رسمي ومصادق عليه.
- 7.7.2 يجب تأمين الأجهزة المحمولة عبر كلمات مرور وقفل تلقائي.
- 7.7.3 يُحظر استخدام شبكات واي فاي عامة دون طبقة حماية إضافية (VPN وتشفير).
- 7.8 استخدام وسائط التخزين الخارجية:
- 7.8.1 يجب فحص جميع وسائط التخزين الخارجية باستخدام برنامج مكافحة فيروسات معتمد.
- 7.8.2 لا يجوز توصيل أي وحدة تخزين بالنظام إلا بعد الحصول على موافقة خطية من مدير تقنية المعلومات.
- 7.8.3 تُوثق عمليات نسخ البيانات الحساسة من وإلى الوسائط، ويُحتفظ بسجلات بذلك لمدة لا تقل عن 6 أشهر.
- 7.9 التطبيقات والبرمجيات:
- 7.9.1 يُمنع تثبيت أي برامج على أجهزة العمل دون موافقة من إدارة تقنية المعلومات.
- 7.9.2 يُلزم المستخدم باستخدام النسخ المرخصة والمحدثة فقط.
- 7.9.3 تُفعل خاصية منع التثبيت الذاتي (Software Installation Lock) في الأجهزة المخصصة للمستخدمين.
- 7.10 الخصوصية والسلوك الرقمي:
- 7.10.1 يُمنع تصوير الشاشة، تسجيل الاجتماعات، أو مشاركة محادثات العمل دون إذن رسمي مسبق.
- 7.10.2 يُمنع استخدام أجهزة الشركة لتصفح مواقع غير مهنية أو التواصل على المنصات الترفيهية.
- 7.10.3 يُحظر الدخول على جهاز زميل دون إذن منه أو من مديره المباشر.
- 7.11 الإبلاغ عن الحوادث:
- 7.11.1 يجب على جميع المستخدمين الإبلاغ الفوري عن أي خرق أمني، أو برامج مشبوهة، أو رسائل تصيد إلكتروني.
- 7.11.2 يُستخدم نظام التذاكر الرسمي للإبلاغ، ويتم تصعيد الحالات الحرجة خلال ساعة واحدة.
- 7.11.3 يتابع الأمن السيبراني الحادث حتى الإغلاق، ويُوثق التقرير ضمن سجل الحوادث.
- 7.12 مغادرة العمل أو تغيير القسم:
- 7.12.1 يجب إيقاف جميع الصلاحيات التقنية فور انتهاء علاقة الموظف بالشركة.
- 7.12.2 يُلزم الموظف بإعادة كافة أجهزة وتقنيات العمل وتوقيع نموذج إخلاء طرف تقني.
- 7.12.3 تُفحص الأجهزة المُعادة وتُمسح بياناتها وفق آلية الحذف الآمن.
- 7.13 الخصوصية والسلوك الرقمي:
- 7.13.1 يُمنع تسجيل الاجتماعات أو المكالمات دون موافقة جميع الأطراف.
- 7.13.2 يُمنع نشر أي محتوى تقني أو معلومات عمل عبر وسائل التواصل الشخصي دون موافقة خطية.
- 7.13.3 يجب احترام خصوصية الزملاء وعدم الدخول على أجهزتهم أو حساباتهم دون تصريح رسمي.
- 7.14 التدريب والوعي الأمني:
- 7.14.1 يُلزم جميع الموظفين بإتمام دورة التوعية الأمنية خلال أول 30 يومًا من التوظيف.
- 7.14.2 تُنظم ورش عمل نصف سنوية عن الأمن السيبراني ويجب حضورها.
- 7.14.3 تُنفذ اختبارات تصيد وهمية لقياس الوعي ويُتخذ إجراء تدريبي عند الفشل.
- 7.15 الالتزام والمجاسية:
- 7.15.1 تُعد مخالفة هذه السياسة خرقًا أمنيًا يُحاسب عليه حسب لائحة الموارد البشرية.
- 7.15.2 تُطبق العقوبات حسب درجة المخالفة (تحذير - إنذار - حسم - فصل).
- 7.16 إطار الامتثال والقياس:
- 7.16.1 تُجرى مراجعات امتثال نصف سنوية من قبل فريق الأمن السيبراني.
- 7.16.2 تُرفع نتائج الامتثال إلى الإدارة التنفيذية وتُقرن بخطة تحسين.

- 7.16.3 تُنفذ اختبارات تقنية دورية للتحقق من الالتزام بالإجراءات.
- 7.17 إشراك الإدارات والتدريب:
- 7.17.1 تُنسق إدارة الأمن السيبراني مع الموارد البشرية والتدريب لضمان إدراج السياسة ضمن برامج التهيئة الوظيفية.
- 7.17.2 تُنشر السياسة مع دليل الموظف ويُدرَّب الموظفون على تطبيقها عمليًا.
- 7.18 الحوسبة السحابية والمشاركة الرقمية:
- 7.18.1 لا يُسمح باستخدام Google Drive أو Dropbox أو iCloud أو أي خدمة تخزين شخصية لحفظ أو مشاركة ملفات العمل.
- 7.18.2 تُستخدم فقط المنصات المعتمدة رسميًا من إدارة التقنية وتخضع للرقابة.
- 7.19 مغادرة العمل أو تغيير الإدارة:
- 7.19.1 تُوقف صلاحيات المستخدم فور انتهاء العلاقة التعاقدية أو انتقاله لقسم آخر.
- 7.19.2 تُعاد جميع الأجهزة، وتُفحص فنيًا وتُمسح بياناتها باستخدام أدوات الحذف الآمن.
- 7.19.3 لا يُمنح الموظف شهادة إخلاء طرف إلا بعد مراجعة سجل استخدامه بالكامل.
- 7.20 المستخدمون الخارجيون وذوو العلاقة:
- 7.20.1 يجب الحصول على موافقة رسمية ومكتوبة من مدير تقنية المعلومات قبل منح أي مستخدم خارجي (مثل الموردين، الاستشاريين، أو موظفي شركات التأمين) صلاحية دخول إلى أنظمة الشركة.
- 7.20.2 يُلزم جميع المستخدمين الخارجيين بتوقيع اتفاقية استخدام مؤقتة تتضمن الالتزام بجميع بنود سياسة أمن المستخدمين.
- 7.20.3 تُمنح الصلاحيات لمدة محددة فقط، ويتم تعطيلها تلقائيًا بانتهاء الغرض من النفاذ أو بانتهاء المدة.
- 7.20.4 يخضع المستخدمون الخارجيون لجميع المتطلبات الأمنية الواردة في هذه السياسة، ويُعاملون معاملة المستخدم الداخلي في حالات المخالفة.
- 7.21 المراقبة اللحظية للنشاطات:
- 7.21.1 يجب على إدارة الأمن السيبراني تفعيل أنظمة مراقبة لحظية (Real-Time Monitoring) لجميع أنشطة المستخدمين داخل الأنظمة الحساسة.
- 7.21.2 يجب تكوين لوحات إنذار فوري لإشعار الفريق التقني عند رصد أي نشاط غير معتاد، مثل: الدخول في وقت غير مصرح، أو محاولة تحميل بيانات بكميات كبيرة.
- 7.22 إساءة استخدام الموارد التقنية:
- 7.22.1 يُمنع منعًا باتًا استخدام موارد الشركة التقنية (مثل البريد الإلكتروني، أجهزة الحاسب، شبكة الإنترنت) لأي غرض شخصي، تجاري، سياسي، أو غير أخلاقي.
- 7.22.2 تُعتبر الأنشطة مثل تنزيل أفلام، برامج مكرسة، أو الدخول لمواقع محظورة، خرقًا صريحًا للسياسة ويُحاسب عليها المستخدم إداريًا.
- 7.23 إدارة الصلاحيات المؤقتة:
- 7.23.1 في حال الحاجة لمنح صلاحية مؤقتة لمستخدم لأداء مهمة محددة (مثل الدعم الفني أو التهيئة)، يجب تقديم طلب رسمي يوضح الغرض، والمدة، والأنظمة المطلوبة.
- 7.23.2 يجب تفعيل آلية مراجعة تلقائية للصلاحيات المؤقتة وتعليقها تلقائيًا بعد انتهاء المدة المحددة.
- 7.23.3 يجب تسجيل كافة الأنشطة التي تمت تحت الصلاحية المؤقتة وتقييم مدى الحاجة لها مستقبلًا.
- 7.24 الاستثناءات:
- 7.24.1 يُمنع أي استثناء من هذه السياسة إلا بعد تقديم طلب خطي واعتماده من مدير الأمن السيبراني.
- 7.24.2 تُوثق جميع الاستثناءات وتُراجع دوريًا لضمان عدم إساءة استخدامها.

8. مسؤولية السياسة:

8.1 مشرف تقنية المعلومات

8.1.1 مسؤول عن ضمان تطبيق هذه السياسة على كافة الأنظمة والتقنيات المعتمدة في الشركة، وتوفير الأدوات اللازمة لتفعيل ضوابطها.

8.2 مسؤول الأمن السيبراني:

8.2.1 مسؤول عن تفعيل أنظمة المراقبة، التوعية، التحقيق في الحوادث الأمنية، وضمان الامتثال الكامل للسياسة، ورفع تقارير دورية للإدارة العليا.

8.3 مديرو الإدارات:

8.3.1 يلتزمون بطلب الصلاحيات اللازمة للموظفين، والتأكد من أن استخدامهم للأنظمة يتم ضمن الإطار المصرح به.

8.4 فريق الدعم الفني:

8.4.1 مسؤولون عن تنفيذ طلبات تعطيل الحسابات، تعديل الصلاحيات، مسح بيانات الأجهزة المنتهية، ومراقبة النشاطات اليومية.

8.5 جميع المستخدمين (داخليين أو خارجيين):

8.5.1 يتحملون المسؤولية الفردية الكاملة عن استخدام حساباتهم وعدم مشاركتها، والالتزام الصارم بجميع ضوابط السياسة.

8.6 إدارة الالتزام والامتثال:

8.6.1 مسؤولون عن مراجعة مدى التزام الإدارات المختلفة بتطبيق الضوابط الأمنية على مستوى المستخدمين.

8.6.2 مسؤولون عن التحقق من وجود آلية فعالة للإبلاغ عن الحوادث التقنية والرد عليها بما يتوافق مع متطلبات الجهات الرقابية.

8.7 إدارة الجودة والتطوير:

8.7.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 إلزاماً لتعميم المواصفات الفنية لنظام المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (197/202010)، بتاريخ 27/10/2020.

9.2 استخدام نظام المراقبة الرقمي في النقل والحفظ الآمن لتسجيلات وبيانات أجهزة المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (224/202110)، بتاريخ 24/10/2021.

9.3 الدليل التنظيمي لأمن المعلومات، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (250/202205)، بتاريخ 26/05/2022.

9.4 تعميم البريد الإلكتروني في حالة الاشتباه بمخالفات، الصادرة عن هيئة التأمين (IA)، برقم (298/2024112)، بتاريخ 26/12/2024.

10. حفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داييموند المعتمدة.

Diamond Insurance Broker

IT User Security Policy

May 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY



Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



إدارة الجودة والتطوير Quality & Development Management

Article (1): This document and the information it contains are related to Al Wathiq Al Massiya Insurance Broker (Diamond). They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

Policy Information				
Policy Title	IT User Security Policy			
Policy Status	Newly Issued			
Previous Policy Title	None			
Previous Policy Date	None			
Document Number	1ITM0003			
Next Review Date	Two years from the date of policy approval or as required			
Policy Owner	Information Technology Management			
Prepared by	Quality & Development Management			
Managements/Functions that Reviewed and Approved the Policy				
Management	Position	Name	Date	Signature
Regulatory Management	Legal and Compliance Manager	Turki Abdullah Al-Abdali	29/07/2025	
Policy Review Lead	Quality & Development Manager	Shaden Sultan Alotaibi	29/07/2025	
Policy Approval				
Senior Management	Managing Director	Badr Saad Al Shaya	29/07/2025	



إدارة الجودة والتطوير
Quality & Development Management

1. Introduction

1.1

The IT User Security Policy is a fundamental part of establishing the general framework for user behavior within the technical work environment and ensuring adherence to security controls that protect the company's information assets and systems.

2. Policy Objective

2.1

Diamond Insurance Brokerage Company (hereinafter referred to as "Diamond") believes that the objective of this policy is to protect the confidentiality, integrity, and availability of information by guiding user behavior toward the secure and responsible use of technical systems and digital infrastructure.

3. Definitions

3.1 Diamond: Diamond Insurance Brokerage Company.

3.2 IT User Security: A set of controls and instructions governing user behavior when using the company's systems, devices, and technologies to protect against cyber threats and misuse.

3.3 User: Any employee, trainee, consultant, or third party who is authorized to use one of the company's IT systems.

3.4 External User: A person not part of the company's permanent organizational structure, such as service providers or insurance partners.

3.5 Temporary Privileges: Access rights granted for a specific period to perform particular tasks, then automatically revoked.

3.6 Critical Systems: Systems involving sensitive data such as the Customer Relationship Management (CRM) system, policy issuance system, and integration systems with insurance companies.

3.7 Unauthorized Usage Behavior: Any behavior that violates this policy's controls, such as unauthorized sharing or transferring data outside secure systems.

3.8 Multi-Factor Authentication (MFA): A security method that verifies user identity using more than one method (e.g., password + mobile verification code).

3.9 VPN (Virtual Private Network): A secure virtual network used to protect communication between the user and internal company systems when working remotely.

3.10 Classified Data: Any data labeled with a security classification such as "Confidential", "Internal", or "Sensitive", and which requires additional protection based on classification policies.

3.11 *(Intentionally left blank or removed)*

3.12 Phishing: A fraudulent technique using emails to trick users and steal their information or gain unauthorized access to company systems.

3.13 IT Asset Management System: An electronic system used to inventory, track, and document all devices and technologies allocated to users.

3.14 IT Clearance: A formal procedure conducted when an employee leaves the company, ensuring the return of equipment and the revocation of technical access rights.

3.15 Unauthorized Software: Any software not approved or licensed by the IT Department, which is prohibited from being

installed or used.

3.16 External Media: Devices such as USBs, external hard drives, and DVDs used to transfer data, subject to strict security controls.

3.17 Tamper Protection: A technical feature that prevents unauthorized modification or disabling of security programs.

3.18 Technical Incident Log: A database used to record all user-related security reports, such as unauthorized access attempts or lost devices.

3.19 Technical Resources: Includes all devices, networks, software, email systems, and company platforms used to perform daily work tasks.

3.20 Real-Time Monitoring: The process of continuously tracking user activities on critical systems using technical tools that trigger instant alerts upon detecting abnormal activity.

3.21 Phishing Tests: Simulated security exercises conducted on employees to measure their awareness of phishing attempts and guide cybersecurity training.

3.22 Temporary Permissions: Privileges granted to a specific user for a limited time to perform a specific task and automatically revoked after the designated period.

4. Scope of Policy Application

4.1

This policy applies to all users of the company's technical systems, including:

4.1.1 Permanent and temporary employees

4.1.2 Trainees and contractors

4.1.3 Authorized external users with access to company systems

5. Related Departments and Divisions

5.1

IT Department

Cybersecurity Division

6. Relevant Entities

6.1

All entities fully owned by Diamond

Authorized technical service providers

Regulatory bodies (Insurance Authority, National Cybersecurity Authority)

10.1 A non-copyable electronic version of the approved policy shall be stored in the Human Resources system, and made accessible to relevant departments.

10.2 A hard copy of the approved policy shall be retained by the Quality and Development Department for the statutory retention period specified in the Document Retention Manual, and shall then be transferred to the official document archiving system.

General Rules

7.1 Responsible Use of System Accounts

7.1.1 All users must use their own personal accounts when accessing any company system. It is strictly prohibited to use another user's account, even with their permission or during their absence. Such behavior constitutes a clear security violation.

7.1.2 Users must maintain the confidentiality of their username and password. Storing credentials in unsecured locations or sharing them verbally, in writing, or electronically is considered a serious security breach.

7.1.3 Users are required to log out from all systems after use and must not leave sessions open.

7.1.4 If a user suspects that their account has been compromised or used in an unauthorized manner, they must immediately report the incident to the Cybersecurity Officer via official email or approved communication channel, including a description of the incident, date, time, and suspicious activity. The incident must be categorized as a "Security Incident."

7.2 Account and Access Management

7.2.1 User accounts must be created based on an official, approved request from the direct manager, clearly specifying the type of account and required privileges.

7.2.2 Account privileges must align with the user's actual job responsibilities. Excessive privileges beyond operational need are strictly prohibited.

7.2.3 User privileges must be reviewed quarterly by the Cybersecurity Department. Accounts inactive for 30 days must be deactivated automatically.

7.2.4 The creation or use of shared or generic accounts is strictly forbidden and constitutes a security breach.

7.2.5 All activities related to user account usage must be logged, including system access, transaction execution, and modifications — especially within critical systems such as CRM and integrations with insurance partners.

7.2.6 These logs must be securely stored in a protected database for no less than ten (10) years, in accordance with Saudi Insurance Authority requirements.

7.2.7 Logs must include detailed information such as: username, date, time, operation type, system name, device used, and geographical location (if applicable).

7.2.8 These logs serve as the primary reference in cases of customer complaints, regulatory investigations, or operational violations.

7.3 Password Protection

7.3.1 Passwords must be complex, with at least 12 characters, including uppercase and lowercase letters, numbers, and symbols.

7.3.2 Users are required to change their password every 90 days and must not reuse previous passwords.

7.3.3 Weak or common passwords (e.g., 123456, admin123) are strictly prohibited.

7.3.4 Account lockout must be activated after five (5) failed login attempts.

7.4 Email and Digital Usage

7.4.1 Official email must only be used for business purposes. It is prohibited to use it for personal accounts or websites.

7.4.2 Opening links or attachments from unknown or suspicious sources is prohibited and must be reported immediately.

7.4.3 Sending confidential information via email without encryption or prior approval from the IT Supervisor is forbidden.

7.4.4 All work-related emails must be retained according to the company's document retention policy.

7.5 Governance of Privileged Accounts

7.5.1 Administrative accounts (e.g., Administrator or Root) must be strictly controlled and their sessions fully logged.

7.5.2 These accounts must not be used for browsing, email, or daily activities.

7.5.3 Administrative account passwords must be changed after each emergency use and should never be shared.

7.6 Network and Remote Access

7.5.4 Accessing company systems from outside the office is only allowed via approved VPNs under security monitoring.

7.5.5 Public Wi-Fi networks must not be used to access company data.

7.5.6 Firewalls and antivirus software must be enabled before connecting to any external network.

7.7 Handling Classified Data

7.6.1 Users must adhere to the company's Information Classification Policy. Sharing, modifying, or transferring classified data without authorization from the data owner is prohibited.

7.6.2 Copying "Confidential" data to portable storage devices without written permission is strictly prohibited.

7.6.3 Classified data must be stored using encryption methods (e.g., AES-256) and under direct technical supervision.

7.8 Working Remotely and On the Move

7.7.1 Access to company systems outside the office is allowed only through an officially approved VPN.

7.7.2 Mobile devices must be secured with passwords and automatic screen lock.

7.7.3 Use of public Wi-Fi without additional security layers (e.g., VPN + encryption) is prohibited.

7.9 Use of External Storage Media

7.8.1 All external storage devices must be scanned using approved antivirus software.

7.8.2 No storage device may be connected to the system without written approval from the IT Manager.

7.8.3 All transfers of sensitive data to and from external media must be logged and retained for at least six (6) months.

7.10 Applications and Software

7.9.1 Installing software on company devices without IT Department approval is prohibited.

7.9.2 Users must only use licensed and updated software.

7.9.3 Software installation must be locked on user-assigned devices (Software Installation Lock).

7.11 Digital Behavior and Privacy

7.10.1 It is prohibited to take screenshots, record meetings, or share work conversations without prior official approval.

7.10.2 Using company devices to access non-professional websites or entertainment platforms is forbidden.

7.10.3 Accessing a colleague's device without their permission or that of their direct manager is prohibited.

7.12 Incident Reporting

7.11.1 All users must report any security breaches, suspicious software, or phishing emails immediately.

7.11.2 The official ticketing system must be used to report incidents. Critical cases must be escalated within one hour.

7.11.3 Cybersecurity will follow up until the incident is resolved and will document the report in the incident log.

7.13 Termination or Department Transfer

7.12.1 All technical access privileges must be revoked immediately upon the employee's departure.

7.12.2 The employee must return all company devices and sign the IT clearance form.

7.12.3 Returned devices must be inspected and securely wiped according to the secure deletion process.

7.14 Privacy and Digital Conduct (Duplicate Reference Number)

7.13.1 Recording meetings or calls without the consent of all participants is prohibited.

7.13.2 Sharing technical content or work-related information on personal social media without written approval is forbidden.

7.13.3 Respecting colleagues' privacy is mandatory; accessing their devices or accounts without formal authorization is prohibited.

7.15 Security Training and Awareness

7.14.1 All employees must complete the cybersecurity awareness course within the first 30 days of employment.

7.14.2 Semi-annual cybersecurity workshops are mandatory for all employees.

7.14.3 Simulated phishing tests will be conducted to assess awareness. Failure will result in mandatory training.

7.16 Compliance and Accountability

7.15.1 Violating this policy constitutes a security breach subject to disciplinary action under the HR policy.

7.15.2 Penalties are applied based on the severity of the violation (Warning – Notice – Deduction – Termination).

7.17 Compliance Framework and Monitoring

7.16.1 Semi-annual compliance reviews will be conducted by the Cybersecurity Team.

7.16.2 Compliance results will be submitted to executive management and tied to an improvement plan.

General Rules (continued)

7.16.3

Regular technical audits must be conducted to verify adherence to established procedures.

7.17 Department Engagement and Training

7.17.1 The Cybersecurity Department shall coordinate with HR and Training departments to ensure the policy is incorporated into onboarding programs.

7.17.2 The policy shall be published alongside the employee handbook, and employees must be trained on its practical application.

7.18 Cloud Computing and Digital Sharing

7.18.1 The use of personal cloud services such as Google Drive, Dropbox, iCloud, or any non-corporate storage platforms to save or share work files is strictly prohibited.

7.18.2 Only officially approved platforms by the IT Department may be used, and they must be subject to security monitoring.

7.19 Employee Departure or Department Change

7.19.1 User privileges must be immediately revoked upon contract termination or transfer to another department.

7.19.2 All devices must be returned, inspected, and securely wiped using certified data erasure tools.

7.19.3 Clearance certificates shall only be issued after reviewing the user's complete activity history.

7.20 External and Affiliated Users

7.20.1 Formal written approval from the IT Manager is required before granting system access to any external user (e.g., vendors, consultants, or insurance company staff).

7.20.2 All external users must sign a temporary usage agreement that includes full compliance with this User Security Policy.

7.20.3 Access permissions shall be granted for a defined period only and automatically revoked once the access purpose or timeframe ends.

7.20.4 External users are subject to all security requirements within this policy and shall be treated as internal users in case of violations.

7.21 Real-Time Activity Monitoring

7.21.1 The Cybersecurity Department must implement real-time monitoring systems for all user activities within critical systems.

7.21.2 Immediate alert dashboards must be configured to notify the technical team upon detecting unusual activity, such as unauthorized access times or bulk data download attempts.

7.22 Misuse of Technical Resources

7.22.1 Company resources (e.g., email, computers, internet) must not be used for personal, commercial, political, or unethical purposes.

7.22.2 Activities such as downloading movies, pirated software, or accessing restricted websites are considered clear policy violations and are subject to administrative action.

7.23 Management of Temporary Privileges

7.23.1 When temporary access is needed (e.g., for technical support or setup), a formal request must be submitted outlining the purpose, duration, and systems required.

7.23.2 Automatic review mechanisms must be activated for temporary privileges, with automatic suspension upon expiration.

7.23.3 All activities performed under temporary privileges must be logged and evaluated to determine future access needs.

7.24 Exceptions

7.24.1 No exceptions to this policy are permitted without a written request approved by the Cybersecurity Manager.

7.24.2 All exceptions must be documented and reviewed periodically to prevent misuse.

8. Policy Responsibilities

8.1 IT Supervisor

8.1.1 Responsible for ensuring the application of this policy across all approved systems and technologies in the company and for providing the tools required to enforce its controls.

8.2 Cybersecurity Officer

8.2.1 Responsible for activating monitoring systems, conducting awareness training, investigating security incidents, ensuring full policy compliance, and submitting regular reports to senior management.

8.3 Department Managers

8.3.1 Responsible for requesting appropriate system access for their team members and ensuring usage stays within authorized boundaries.

8.4 Technical Support Team

8.4.1 Responsible for executing account deactivation requests, modifying privileges, wiping returned devices, and monitoring daily activities.

8.5 All Users (Internal and External)

8.5.1 Personally accountable for the proper use of their accounts, non-sharing of credentials, and strict adherence to all provisions of this policy.

8.6 Compliance Department

8.6.1 Responsible for reviewing the compliance of various departments with user-level security controls.

8.6.2 Ensures the existence of an effective mechanism for reporting and responding to technical incidents in line with regulatory authority requirements.

8.7 Quality and Development Department

8.7.1 Responsible for ensuring this policy is effectively implemented through regular audits and reviews.

9. Related Circulars and Guidelines

9.1 As per the Technical Specifications Circular for Video Surveillance Systems, issued by the Saudi Central Bank (SAMA), No. (202010/197), dated 2020/10/27.

9.2 Regarding the use of digital surveillance systems for the secure transmission and storage of video surveillance data, issued by SAMA, No. (202110/224), dated 2021/10/24.

9.3 Information Security Governance Framework, issued by SAMA, No. (202205/250), dated 2022/05/26.

9.4 Email Reporting Circular in Case of Suspected Violations, issued by the Insurance Authority (IA), No. (2024112/298), dated 2024/12/26.

10. Policy Retention

10.1

The approved electronic version of this policy, which is non-copyable, shall be stored on the Human Resources Management System and made accessible only to relevant departments.

10.2

The approved hard copy of the policy shall be retained by the Quality and Development Department in accordance with the statutory retention period specified in the Document Retention Handbook. It shall then be formally archived as per company procedures.

11. Policy Violations:

11.1 Any violation of this policy shall be subject to the disciplinary actions outlined in the approved Diamond Company Sanctions Regulation.